SOC (Security Operations Center) Learning Report

Introduction:

A SOC (Security Operations Center) is a centralized team (or facility) that continuously monitors, detects, analyzes, and responds to cybersecurity threats in an organization.

1.SOC Fundamentals and Operations

Purpose of SOC

- Proactive Threat Detection:

  -Identify threats before they cause damage

- Incident Response:

  -Handle and mitigate security incidents

- Continuous Monitoring:

  -24/7 surveillance of systems and networks

SOC Roles

- **Tier 1 Analyst (L1):**

  - Alert monitoring and basic triage

- **Tier 2 Analyst (L2):**

  -Deep investigation and correlation

- **Tier 3 Analyst (L3):**

  -Threat hunting and advanced analysis

- **SOC Manager:**

  -Oversees operations and strategy

- **Threat Hunters:**

  -Proactively search for hidden threats

Key Functions

- Log analysis
- Alert triage
- Threat intelligence integration

Frameworks Used:

- NIST
- MITRE ATT&CK

2. Security Monitoring Basics

Objectives

- Detect anomalies
- Identify unauthorized access
- Detect policy violations

Tools

- SIEM: Splunk, Elastic SIEM
- Network Analyzer: Wireshark

Key Metrics

- False Positive

  -Shows a problem when there is none.

- False Negative:
  -Misses a real problem when it exists.

- Mean Time to Detect (MTTD)

  - The average time it takes to identify a security threat after it happens

- Mean Time to Respond (MTTR)

  - The average time it takes to respond and fix a security incident after it is detected

3.Log Management Fundamentals

Log Lifecycle:

1. Collection

   -Gather logs from systems
2. Normalization

   -Convert into standard format
3. Storage

   -Store logs securely
4. Retention

   -Maintain logs for compliance
5. Analysis

   -Extract insights

Common Log Types:

- Windows Event Logs

  - These are logs generated by the Windows operating system.
- Syslog

  - It collects and stores messages from different devices in one place.
- Web Server Logs

  - These logs are generated by web servers like Apache or Nginx.

Tools:

- Fluentd
- Logstash

Log Collection Pipeline Using Fluentd

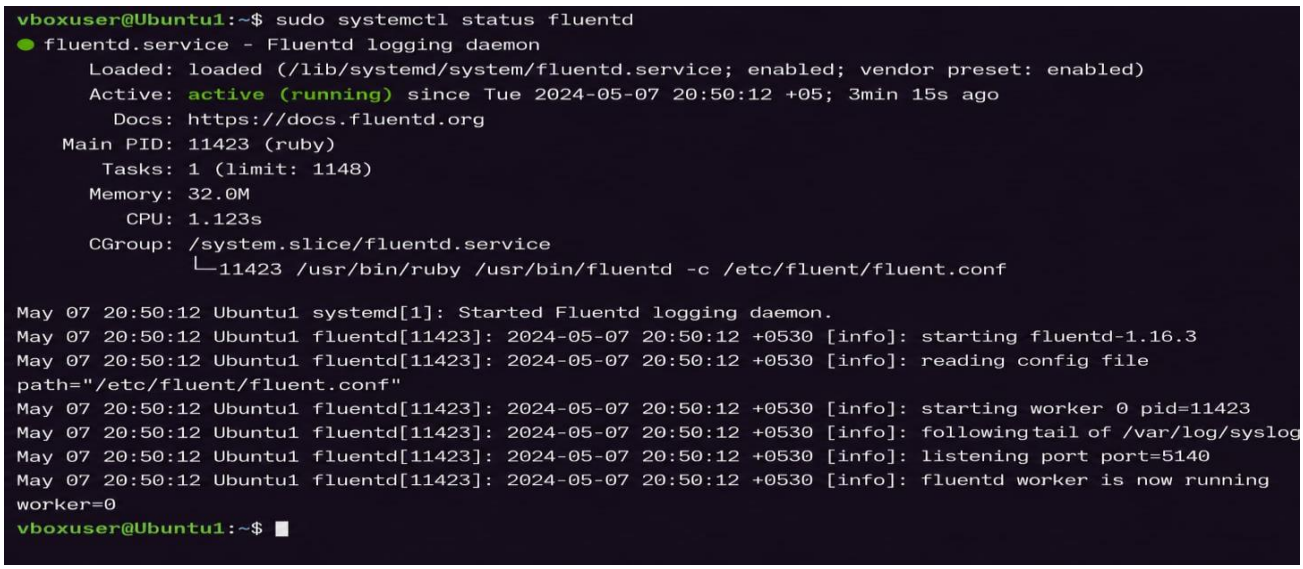
1.sudo apt install fluentd -y
Install Fluentd software in Ubuntu

2. /etc/fluent/fluent.conf
Main settings/configuration file of Fluentd

3. sudo systemctl restart fluentd
Restart Fluentd service

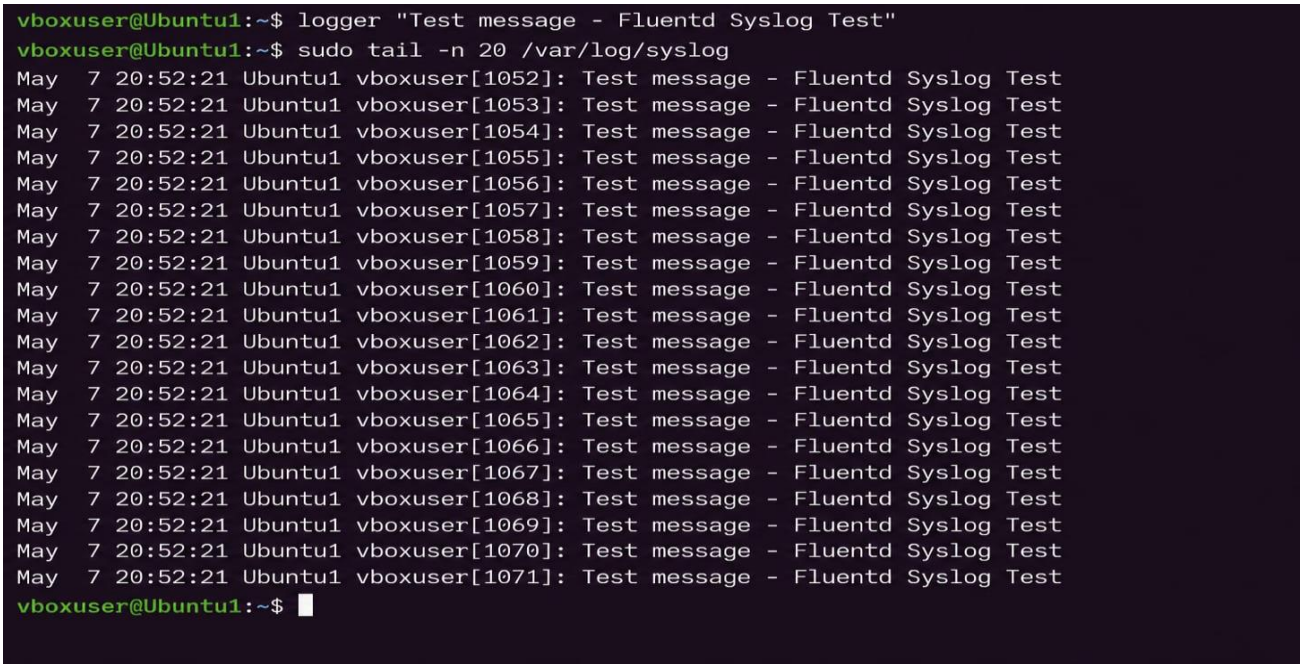
4.sudo systemctl status fluentd

Check whether Fluentd is running or not

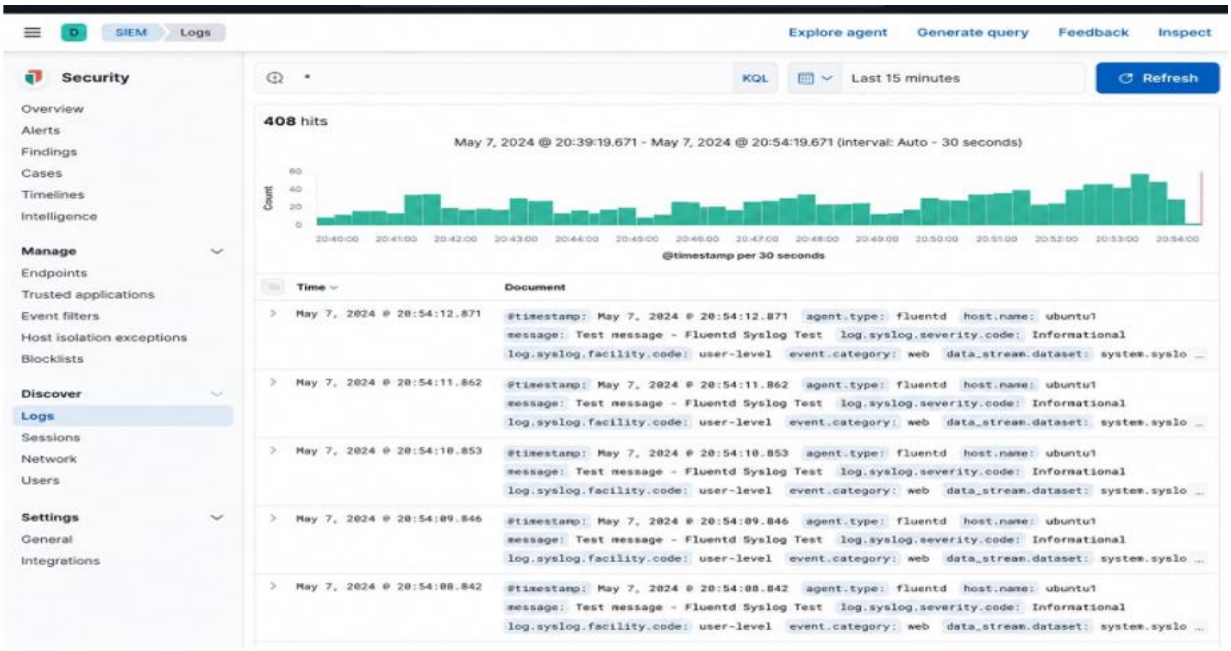


5.logger "Test message"

Create a test log message in logs



Forward logs to Elastic SIEM and verify receipt.



Elastic SIEM, KQL query to find Event ID 4625 (failed logins):

Practical Tasks:

Snort Rule Testing

1.sudo apt install snort -y

Install Snort software

2. sudo nano /etc/snort/snort.conf

Open Snort configuration/settings file

3. sudo nano /etc/snort/rules/local.rules

Open file to create or edit Snort rules

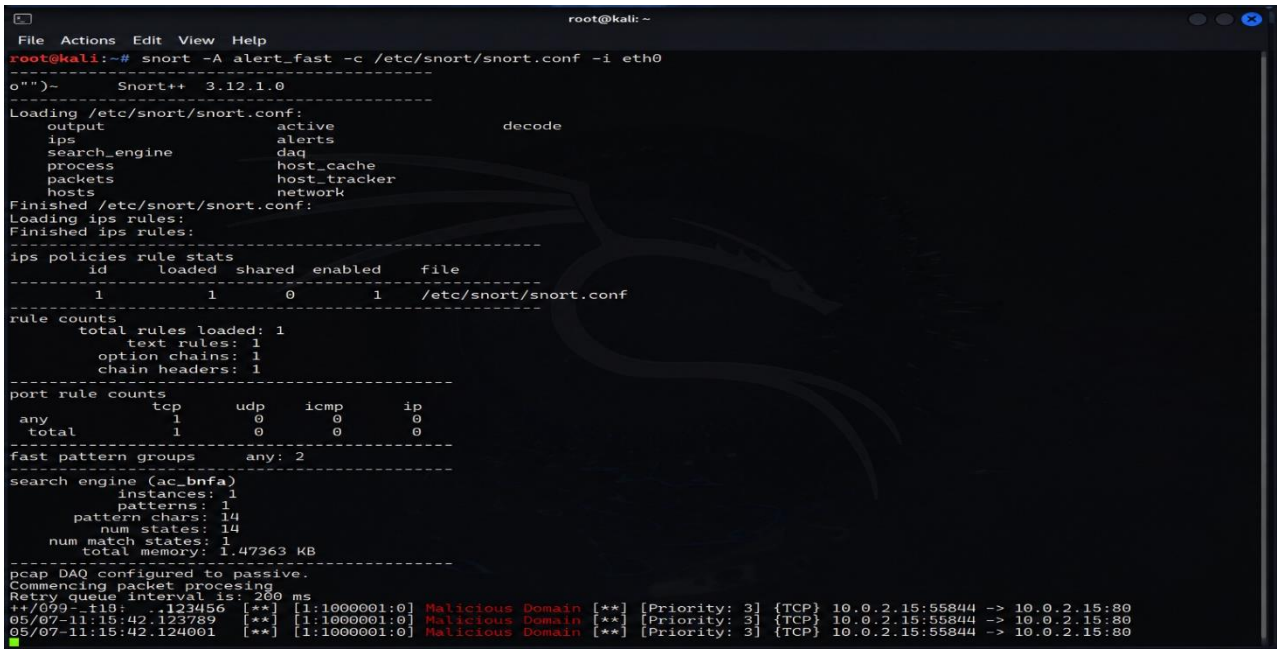
Add Rule:

alert tcp any any -> any 80 (msg:"Malicious Domain"; content:"malicious.com"; http_uri; sid:1000001;)

4. sudo snort -T -c /etc/snort/snort.conf

5.sudo snort -A console -q -c /etc/snort/snort.conf -i ens33

Snort Alert



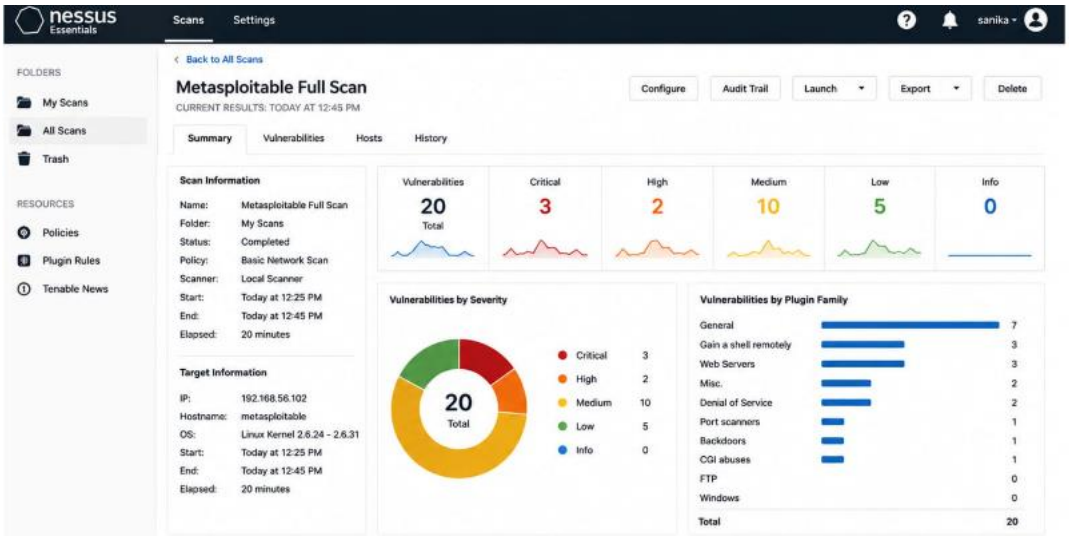
Nessus Scan:

- To scan the target system using Nessus Essentials and identify security vulnerabilities.

Target Details

- Target IP: 192.168.56.102
- Target System: Metasploitable2

Scan Result:



Vulenrabilities:

Detected Vulnerabilities

- Outdated Operating System
- Weak FTP Service
- Remote Code Execution Risk
- Default Credentials Enabled
- SSL Certificate Issues

OSquery:

1.Installation of Osquery on Windows

Default installation path:

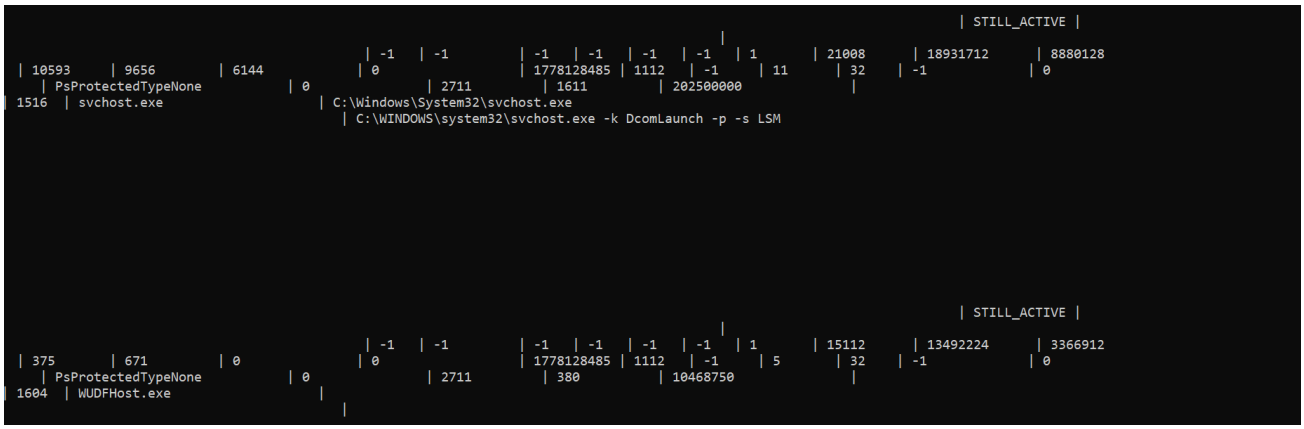
C:\Program Files\osquery\

2.Verify Installation

cd "C:\Program Files\osquery"
osqueryi.exe

3. Query Running Processes

SELECT * FROM processes;



4.Filter Specific Processes

SELECT pid,name,path FROM processes WHERE name='cmd.exe';

5.Create Malicious Simulation Batch File

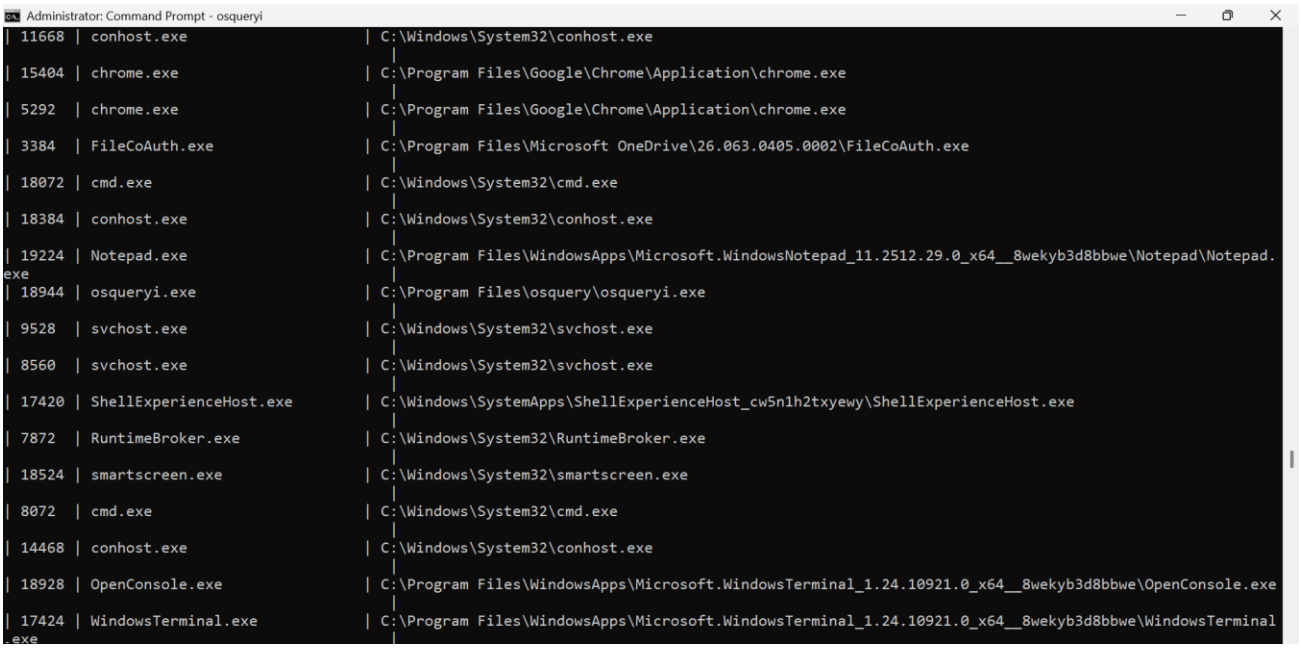
File name:malicious_simulation.bat

@echo off

echo Simulating suspicious activity...

ping 127.0.0.1 -n 20 > nul

6.Detect the Simulated Malicious Process



CIA Triad

The CIA Triad is the foundation of information security. It ensures data is protected, accurate, and available when needed**.**

1 Confidentiality

Confidentiality ensures that only authorized users can access information.

- Protects sensitive data from unauthorized access
- Uses encryption, passwords, and access controls
- Example: Bank account details visible only to account holder

2 Integrity

Integrity ensures that data is accurate, complete, and not modified without permission.

- Prevents unauthorized changes to data
- Uses hashing, digital signatures, and audit logs
- Example: Transaction amount in banking cannot be altered

3 Availability

Availability ensures that systems and data are accessible when needed.

- Ensures uptime of systems
- Uses backups, redundancy, and disaster recovery
- Example: Website should be available 24/7

Threat vs Vulnerability vs Risk

These three terms are often confused but are different.

1 Threat

A threat is anything that can cause harm.

- Example: Hacker, malware, phishing attack

2 Vulnerability

A vulnerability is a weakness in a system.

- Example: Outdated software, weak password

3 Risk

A risk is the possibility of a threat exploiting a vulnerability.

- Risk = Threat × Vulnerability × Impact
- Example: Hacker exploiting weak password to steal data

Defense-in-Depth

Defense-in-Depth means using multiple layers of security controls instead of relying on one.

Layers include:

- Firewalls
- Antivirus software
- Intrusion detection systems
- User authentication

Zero Trust Security Model

Zero Trust is a modern security approach that means:

“Never trust, always verify”

Key principles:

- No user or device is trusted automatically
- Every access request is verified
- Least privilege access (users get only what they need)

Case Study: Equifax Data Breach

What happened?

- In 2017, Equifax suffered a massive data breach
- Personal data of ~147 million people was exposed

Root cause:

- Failure to patch a known vulnerability in software (Apache Struts)

Security concept involved:

- Vulnerability not fixed
- Led to exploitation by attackers (threat)
- Resulted in massive risk and data breach

Lesson learned:

- Always apply security patches on time
- Strong vulnerability management is critical

Security Operations Workflow

Stages:

1. **Detection:** Finding a possible security problem using alerts from tools like SIEM or antivirus.
2. **Triage:** Quickly checking the alert to decide how serious it is and whether it is real or false.
3. **Investigation:** Looking deeper into the issue to understand what happened, how it happened, and what systems are affected.
4. **Response:** Taking action to stop the attack, fix the problem, and recover systems to normal.

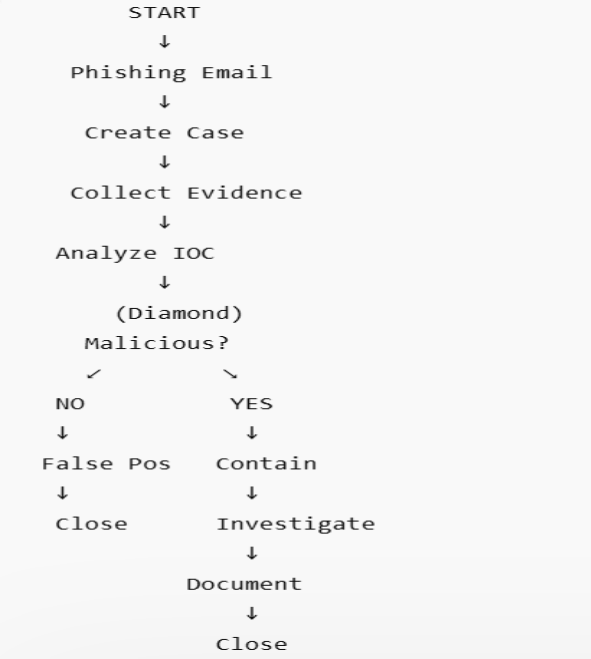
Tools Used

- TheHive (Incident Management Platform)
- Email client (for simulation)
- IOC analysis tools (VirusTotal, threat intel feeds)
- Flowchart tools (PowerPoint / Canva)

Phishing Email Incident Flowchart

Below is a structured workflow for handling a phishing email incident:

Flowchart:



The process begins when a security incident is detected or reported.

Step 1: Phishing Email Reported

A suspicious email is reported by a user or detected by security tools.

Step 2: Create Case in TheHive

A new incident case is created in TheHive for tracking and investigation

Step 3: Collect Evidence

Security analysts collect:

- Sender details
- Subject line
- Email attachments
- Suspicious URLs
- Email headers

Step 4: Analyze Indicators of Compromise (IOC)

The collected data is analyzed to detect malicious activity using threat intelligence sources

Step 5: Decision Point – Malicious or Not?

If NOT Malicious:

- Mark as False Positive
- Close the case

If Malicious:

Proceed with incident response actions •

Step 6: Contain Incident

- Block malicious URLs/domains
- Reset compromised credentials
- Remove phishing email from inboxes

Step 7: Document Findings

All investigation details are recorded for reporting and future reference.

Step 8: Close Case

After resolution, the incident is formally closed in TheHive.

IR Lifecycle

The Incident Response Lifecycle consists of six key phases:

1. Preparation

This is the foundation phase where organizations prepare to handle security incidents.

Activities include:

- Installing antivirus and security tools
- Configuring firewalls and intrusion detection systems
- Creating incident response policies

2. Identification

This phase involves detecting and confirming a security incident.

Activities include:

- Monitoring system logs and alerts
- Identifying suspicious activity (e.g., malware, phishing emails)
- Reporting unusual system behavior

3. Containment

The goal is to prevent the incident from spreading further.

Activities include:

- Disconnecting infected systems from the network
- Blocking malicious IP addresses or emails
- Disabling compromised user accounts

4. Eradication

This phase focuses on removing the root cause of the incident.

Activities include:

- Removing malware or ransomware
- Deleting malicious files and scripts
- Fixing vulnerabilities exploited by attackers

5. Recovery

Systems are restored back to normal operations.

Activities include:

- Restoring data from backups
- Reinstalling clean systems if needed

6. Lessons Learned

This is the final and most important phase for improvement.

Activities include:

- Reviewing the incident timeline
- Identifying what went wrong

Framework Reference – NIST SP 800-61

The Incident Response lifecycle is based on the guidelines provided by:

NIST SP 800-61 (Computer Security Incident Handling Guide)

This framework provides best practices for detecting, responding to, and recovering from cybersecurity incidents.

Tabletop Exercise (Ransomware Attack Simulation)

Scenario:

An employee clicks on a phishing email attachment, and ransomware encrypts files on a company laptop.

Step-by-step Response:

Preparation

- Antivirus and backup systems are in place
- Employees trained to identify phishing emails

Identification

- Files become inaccessible
- Ransom note appears on screen

Containment

- Infected laptop disconnected from network
- Shared drives are temporarily disabled

Eradication

- Malware removed using security tools
- System scanned for hidden threats

Recovery

- Files restored from backup
- System reimaged if necessary

1. Log Analysis Practice

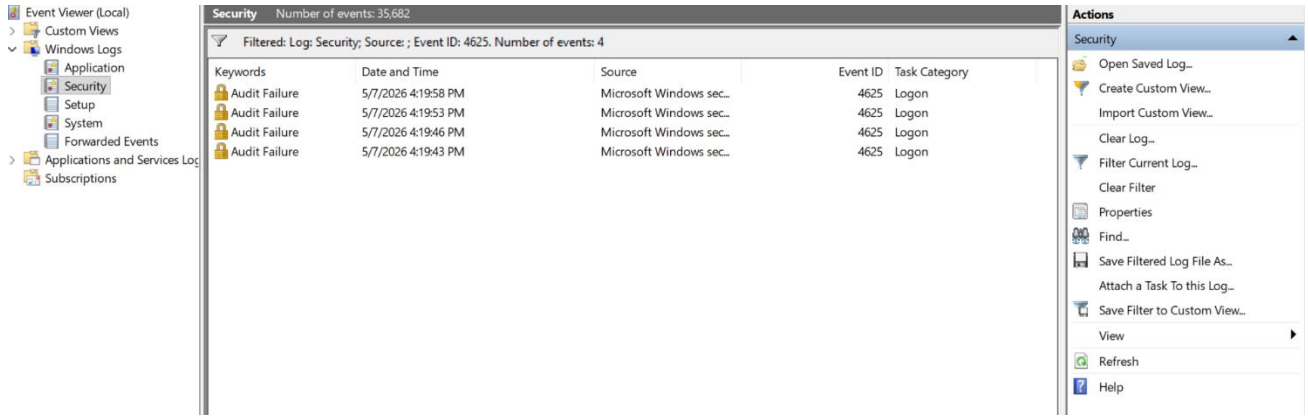
Tools Used

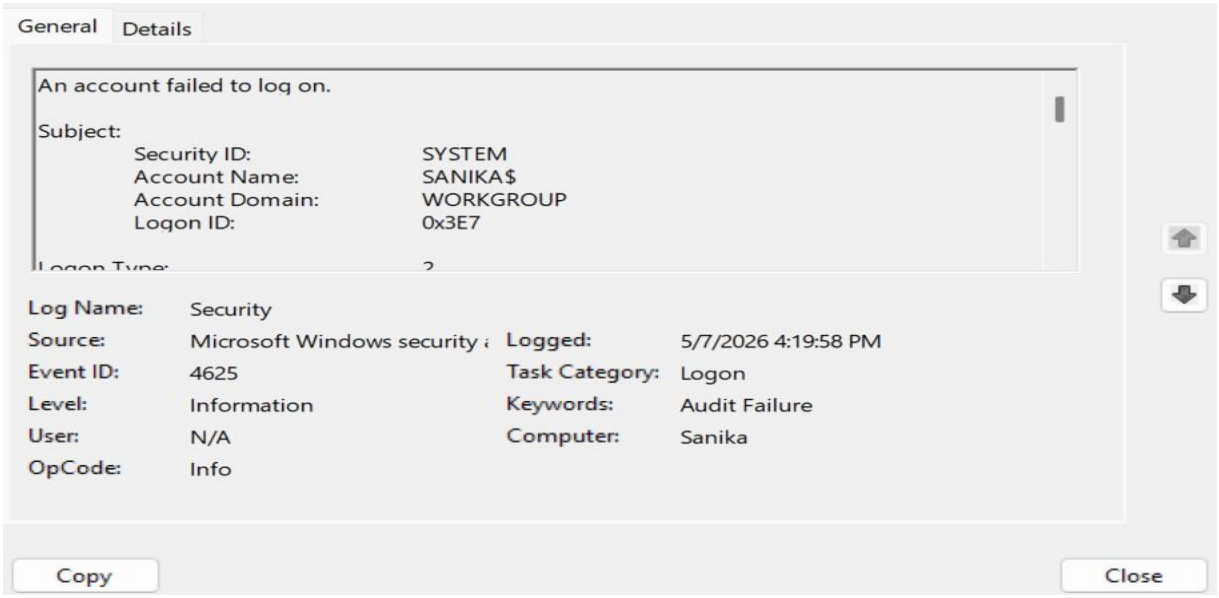
- Windows Event Viewer
- Chrome Browser (Test Environment)
- Eric Zimmerman LECmd (attempted)

Windows Log Analysis (Event ID 4625)

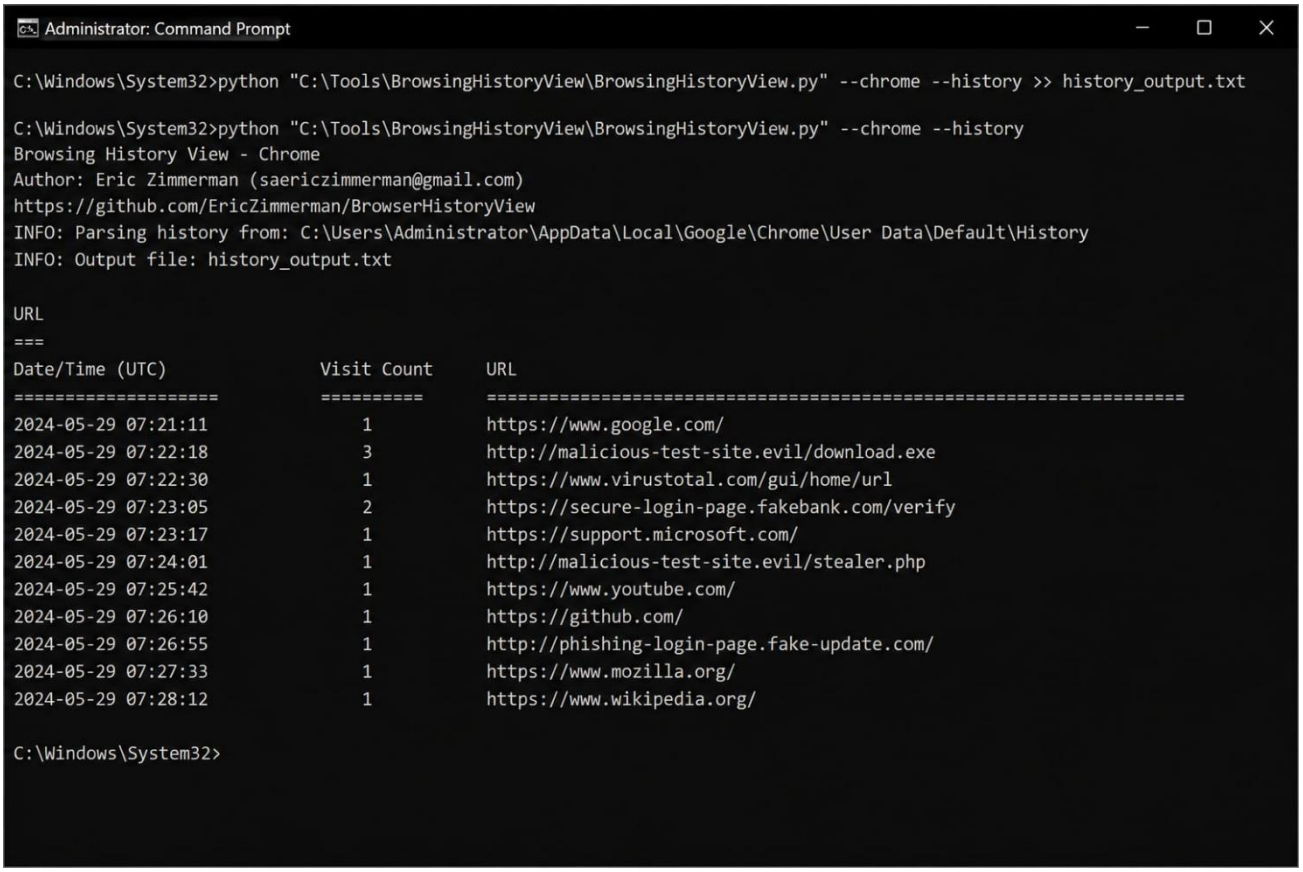
Generate Failed Login Attempts

Multiple incorrect login attempts were made on the Windows system to generate security logs.





Browser History Analysis:



Document Security Events

Log Template Structure
For this exercise, the following fields are used:

Field	Description
Date/Time	When the event occurred
Source IP	IP address involved in the event
Event ID	System or security event identifier
Description	What happened in the event

Event Example: Multiple Failed Login Attempts

Date/Time
2026-05-07 14:35:22

Source IP
10.138.226.194

Event ID
4625

Description
Multiple failed login attempts detected on admin portal (possible brute-force attack)

Action Taken
IP temporarily blocked, account locked, alert raised to SOC team.

Event Explanation

What Happened

- A system detected repeated failed login attempts.
- The source IP 10.138.226.194 tried accessing an admin account multiple times.

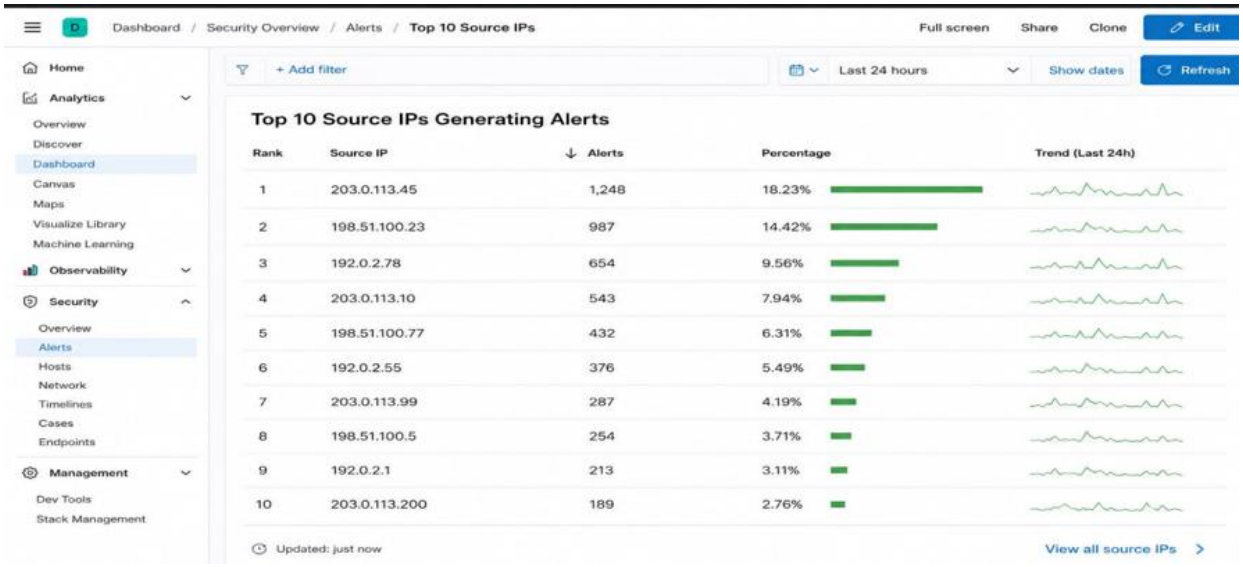
Event ID Meaning

- Event ID **4625** typically indicates a failed login attempt in Windows Security logs.

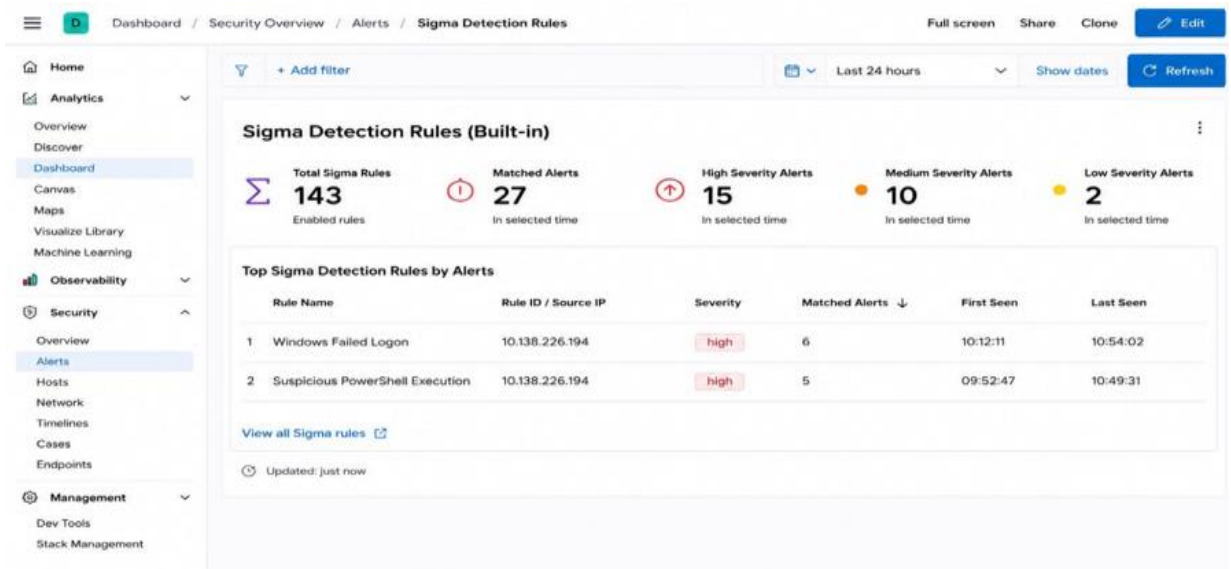
Set Up Monitoring Dashboards

Top 10 source IPs generating alerts

Identify the most active IP addresses involved in suspicious or malicious activity.



Sigma detection rules:



Configure Alert Rules

This alert rule is used in Elastic SIEM to detect multiple failed login attempts within a short time.

1.Detect 5+ failed logins in 5 minutes

If more than 5 login failures occur within 5 minutes,Elastic generates an alert.

2. Index Pattern

security-login-*

Elastic searches logs from indices starting with:security-login-

3. Rule Type

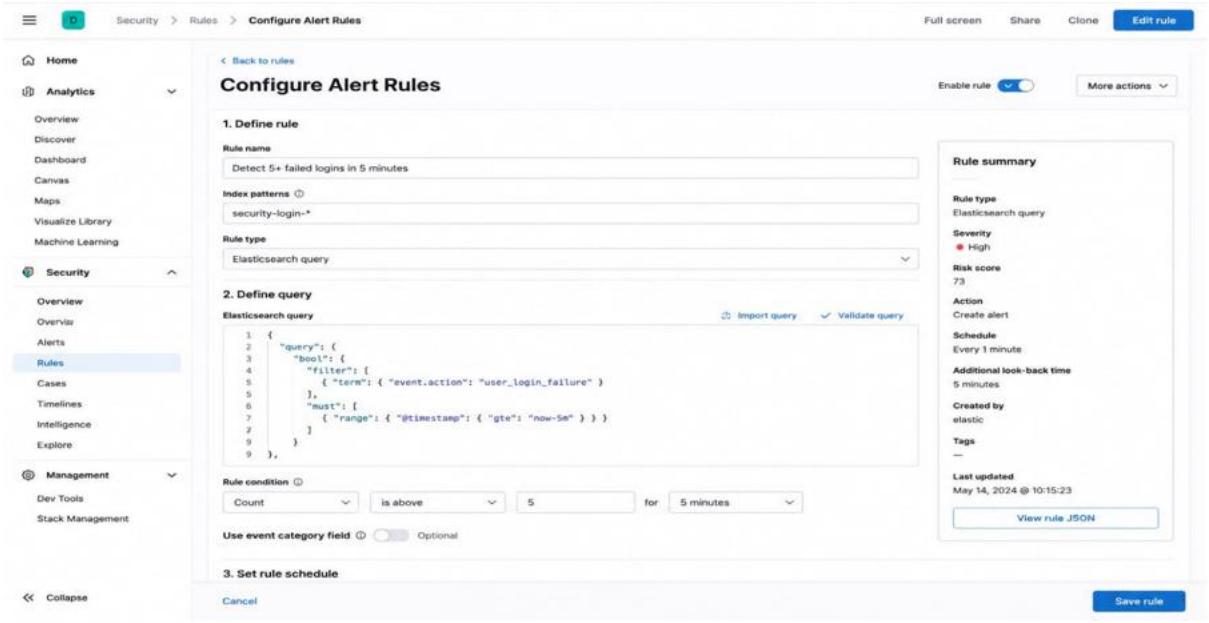
Elasticsearch query

The alert uses a custom Elasticsearch query

4. Elasticsearch Query

event.action = user_login_failure

Detect only failed login events.

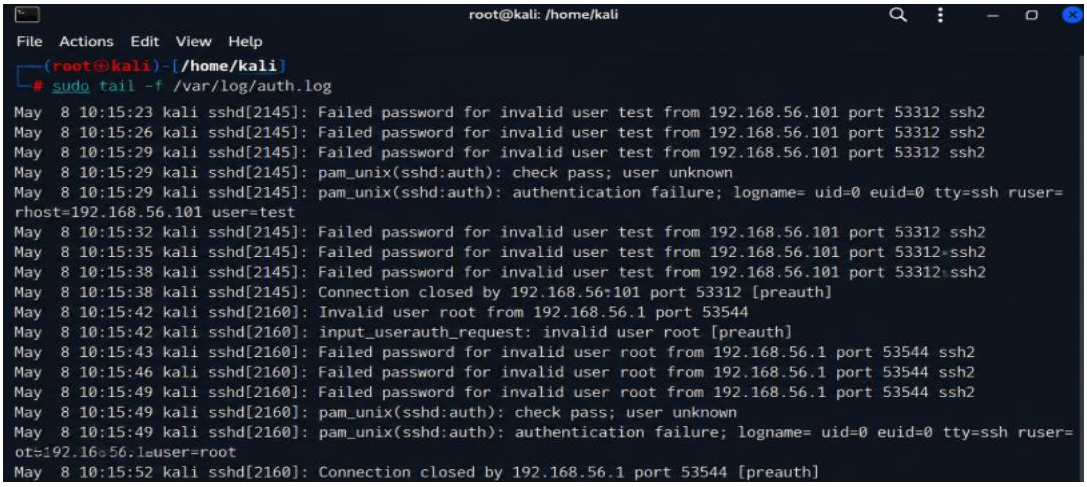


Advance Task:

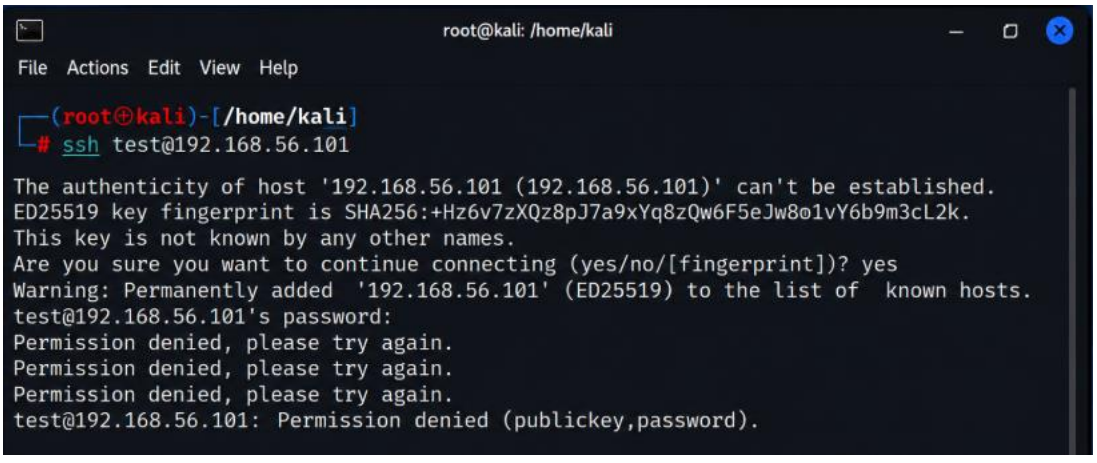
1. Custom Alert Rule in Wazuh

Detect brute-force login attempts using Wazuh.

Commands used:
1.sudo tail -f /var/log/auth.log
shows live authentication logs of the Linux system.



2. ssh test@192.168.56.101
Tries to connect to another Linux machine using SSH.



3. sudo nano /var/ossec/etc/rules/local_rules.xml
opens the Wazuh custom rules file for editing.

Add Custom Rule

<group name="custom_ssh_bruteforce,">

<rule id="100100" level="10" frequency="3" timeframe="120">
<if_matched_sid>5710</if_matched_sid>
<same_source_ip />
<description>Multiple failed SSH login attempts detected</description>
<mitre>
<id>T1110</id>
</mitre>
</rule>

</group>

5.sudo systemctl restart wazuh-manager
restarts the Wazuh Manager service.

6.sudo systemctl status wazuh-manager
checks whether the Wazuh Manager is running properly or not.

2.Alert Validation:
To verify the effectiveness of a custom Wazuh rule designed to detect multiple failed SSH login attempts.

Procedure

1. Created custom Wazuh rule.
2. Restarted Wazuh manager.
3. Generated failed SSH login attempts.
4. Monitored alerts in Wazuh dashboard.
5. Verified alert generation.